paiement-api — SEPA transfer microservice — RTS 2024/1774 · Politique interne PDS-2 (Banque Kerlann, fictive)

Banque Kerlann (fictitious) · paiement-api — SEPA transfer microservice

Prepared by: **Attest (AI-assisted)**

Auditor sign-off: **pending (work programme reviewed by Attest CI)**

Owner: **IT department — Payments development team**

Date: **2026-11-04 05:55**

Run: **20261104-055531-9eb4**

1. Executive summary

OPINION AT TESTING

Unsatisfactory

Basis for opinion

10 controls tested (10 conclusive) against: RTS 2024/1774 — article 16 : acquisition, développement et maintenance des systèmes TIC · Politique interne PDS-2 (Banque Kerlann, fictive) — développement sécurisé. Tests run on 2026-11-04 05:55, environment: Demonstration pre-production. The opinion rests solely on the verdicts of the deterministic test scripts and on the evidence sealed in the audit trail.

Scope limitation: Test scripts drafted by AI and not yet reviewed by an auditor; requirements needing document review or interview are not covered; the opinion applies at the test date only.

10 controls tested	**9** findings	**0** findings closed and verified	**9** open findings
0 human approvals	**19** sensitive data items masked in evidence	**5 min 46 s** audit duration	**$0.738 *** measured AI cost



Critical: 1 High: 4 Medium: 4 Low: 0

Key messages

- 9 findings across 10 controls: 1 critical, 4 high, 4 medium.
- 9 findings remain open, with an action plan, an owner and a due date.

2. Scope and method

Engagement	AUD-20261104-9EB4

Entity	Banque Kerlann (fictitious)
System	paiement-api — SEPA transfer microservice
System criticality	Supports critical or important functions (DORA)
Environment	Demonstration pre-production
Owner	IT department — Payments development team
Lead auditor	Attest CI
Date	2026-11-04 05:55
Framework	RTS 2024/1774 — article 16 : acquisition, développement et maintenance des systèmes TIC · Politique interne PDS-2 (Banque Kerlann, fictive) — développement sécurisé
Audited target	paiement-api code repository (SEPA transfer microservice)
Work programme	reviewed by an auditor (Attest CI) · runs/studio/20261104-055531-9eb4/catalogue.json

In scope

- Source code, configuration and CI pipeline of the repository
- Versioned test datasets

Out of scope

- Dynamic testing (DAST) and penetration testing
- Runtime and production environments
- Git history

Method

1. Controls are derived from the framework (DORA, RTS 2024/1774, internal policy); severity is the one set by the policy.
2. Each test is a stored Python script, statically checked before execution (read-only) and run with a read-only service account.
3. The verdict comes from the script, never from the model. A screenshot is reviewed by Muse Spark to corroborate; on disagreement the control is flagged for review.
4. SAM 3.1 delineates the proving rows and the personal data, which is masked before distribution.
5. Every fix goes through a change request approved by the system owner, applied with a dedicated account, logged, then verified by the same test (DORA 9(4)(e)).
6. Every event and piece of evidence is sealed in a hash-chained audit trail (SHA-256).

Limitations

- Tests cover the configuration reported by the system, not the actual strength of authentication factors.
- AI-drafted scripts and catalogue must be reviewed by an auditor before being considered validated.
- Fixes are drafted by the audit tool itself (self-review threat): closing a finding requires independent approval by the system owner.
- Fictitious entity and data: demonstration.

3. Findings overview

REF.	RULE	TITLE	SEVERITY	TESTED	AFTER	STATUS	DUE DATE
F-01	PDS-2.1	No hardcoded secrets in code or versioned config	Critical	Non-compliant		Open	2026-12-04

F-02	PDS-2.2	TLS certificate verification never disabled	High	Non-compliant	Open	2027-02-02
F-03	PDS-2.3	Password hashing uses approved algorithm	High	Non-compliant	Open	2027-02-02
F-04	PDS-2.3	MD5 and SHA-1 banned for security use	High	Non-compliant	Open	2027-02-02
F-05	PDS-2.6	No versioned production export	High	Non-compliant	Open	2027-02-02
F-06	PDS-2.7	Authentication successes and failures logged	Medium	Non-compliant	Open	2027-05-03
F-07	PDS-2.4	CI runs static security analysis	Medium	Non-compliant	Open	2027-05-03
F-08	PDS-2.5	Dependencies pinned to exact version	Medium	Non-compliant	Open	2027-05-03
F-09	PDS-2.5	Dependencies audited in CI	Medium	Non-compliant	Open	2027-05-03
—	PDS-2.6	Test data declared synthetic	High	Compliant		

4. Detailed findings and controls

F-01 PDS-2.1 No hardcoded secrets in code or versioned config

Critical · Non-compliant · Open

CRITERIA

Verify no clear-text passwords, keys or tokens are versioned.

PDS-2.1 · RTS 7(2)

Threshold source: PDS-2.1

> *« Aucun secret (mot de passe, clé, jeton) n'est écrit en clair dans le code source ni dans la configuration versionnée : les secrets viennent d'un coffre ou de variables d'environnement. »*

CONDITION

Observed: `{"search_matches": [], "local_matches": [{"path": "app/config.py", "line": 6, "text": "DB_PASSWORD = \"Az••••\" # TODO : déplacer dans le coffre-fort"}, {"path…`

Expected: `Zero matches for hardcoded secret assignments; secrets only via vault or environment variables.`

Found 2 hardcoded secret assignments in app files with search returning 0 matches.

RISK

Hardcoded secrets enable credential theft and unauthorized access.

RECOMMENDATION

Remove clear-text secrets and load them from vault or environment variables.

Due date: 2026-12-04 · Owner: IT department — Payments development team

Test procedure: GET /api/repo/paiement-api/tree to list files, GET /api/repo/paiement-api/file?path=app/config.py and other app/ files, and GET /api/repo/paiement-api/search?q=(password|passwd|secret|api_key|token)\s*=\s*['"]. Verify secrets are loaded via os.environ, os.getenv or vault client.



At testing — The screenshot corroborates the test. The screenshot shows hardcoded DB_PASSWORD and JWT_SECRET values in app/config.py. · 3/3 sensitive data items masked (2 spotted by the AI, the rest by the deterministic safety net)
`2026-11-04 05:57:35 · SHA-256 d881586620510d24…`

F-02 PDS-2.2 TLS certificate verification never disabled

High | Non-compliant | Open

CRITERIA

Verify no outbound call disables TLS certificate verification.
PDS-2.2 · DORA 9(3)(a) ; RTS 6(2)(a)
Threshold source: PDS-2.2

> *« Tout appel réseau sortant vérifie le certificat TLS du serveur : la vérification n'est jamais désactivée (`verify=False` interdit). »*

CONDITION

Observed: `{"verify_False_count": 1, "verify_0_count": 0, "matches": [{"line": 18, "path": "app/payments.py", "text": "response = requests.post(PSP_URL, json=payload, time…`
Expected: `Zero matches for verify=False; all TLS calls verify certificates.`
Search found 1 matches for verify=False and 0 matches for verify=0.

RISK

Disabled verification allows man-in-the-middle interception.

RECOMMENDATION

Remove verify=False and enforce TLS certificate verification.
Due date: 2027-02-02 · Owner: IT department — Payments development team

Test procedure: GET /api/repo/paiement-api/search?q=verify\s*=\s*False and GET /api/repo/paiement-api/search?q=verify\s*=\s*0. GET /api/repo/paiement-api/file?path=app/service.py to review outbound requests usage.



At testing — The screenshot corroborates the test. Line 18 in app/payments.py shows verify=False, matching the automated test failure.
2026-11-04 05:58:04 · SHA-256 03ffbdd593d56b5c…

F-03 PDS-2.3 Password hashing uses approved algorithm

High · Non-compliant · Open

CRITERIA

Verify passwords are hashed only with argon2, bcrypt, scrypt or PBKDF2.
PDS-2.3 · RTS 6(3) et 6(4)
Threshold source: PDS-2.3

> *« Les mots de passe sont hachés avec argon2, bcrypt, scrypt ou PBKDF2. MD5 et SHA-1 sont interdits pour tout usage de sécurité. »*

CONDITION

Observed: `{"search_matches": [], "app_auth_py": "\"\"\"Authentification des opérateurs back-office.\"\"\"\nimport hashlib\n\nfrom .db import get_operator\n\n\ndef hash_pa…`
Expected: `Password hashing uses only argon2, bcrypt, scrypt or PBKDF2.`
app/auth.py uses MD5 or SHA-1 hashing instead of only argon2, bcrypt, scrypt or PBKDF2.

RISK

Weak hashing allows password recovery after database theft.

RECOMMENDATION

Use argon2, bcrypt, scrypt or PBKDF2 for password hashing.
Due date: 2027-02-02 · Owner: IT department — Payments development team

Test procedure: GET /api/repo/paiement-api/search?q=argon2|bcrypt|scrypt|pbkdf2 and GET /api/repo/paiement-api/file?path=app/auth.py to review password hashing implementation.



At testing — The screenshot corroborates the test. The screenshot shows app/auth.py implementing hash_password with hashlib.md5.
2026-11-04 05:57:20 · SHA-256 9b670c1eafd915cb…

F-04 PDS-2.3 MD5 and SHA-1 banned for security use

High · Non-compliant · Open

CRITERIA

Verify MD5 and SHA-1 are not used for security purposes.
PDS-2.3 · RTS 6(3) et 6(4)
Threshold source: PDS-2.3

> *« Les mots de passe sont hachés avec argon2, bcrypt, scrypt ou PBKDF2. MD5 et SHA-1 sont interdits pour tout usage de sécurité. »*

CONDITION

Observed: `{"search_total": 1, "search_matches": [{"line": 8, "path": "app/auth.py", "text": "return hashlib.md5(password.encode()).hexdigest()"}] "auth_hits": [{"line": …`
Expected: `Zero matches for MD5 or SHA-1 in security use.`
Found 1 MD5 or SHA-1 references in app/auth.py indicating security use.

RISK

MD5 and SHA-1 are collision-prone and unsuitable for security.

RECOMMENDATION

Remove MD5 and SHA-1 for any security use.
Due date: 2027-02-02 · Owner: IT department — Payments development team

Test procedure: GET /api/repo/paiement-api/search?q=\bmd5\b|\bsha1\b|hashlib\.md5|hashlib\.sha1|hashlib\.sha_1 and review matches in GET /api/repo/paiement-api/file?path=app/auth.py.



At testing — The screenshot corroborates the test. The screenshot shows line 8 hashing passwords with hashlib.md5.
`2026-11-04 05:57:08 · SHA-256 9b670c1eafd915cb…`

F-05 PDS-2.6 No versioned production export

High · Non-compliant · Open

CRITERIA

Verify no production export is versioned.
PDS-2.6 · RTS 16(5)(a)
Threshold source: PDS-2.6

> *« Les données de test sont synthétiques et déclarées comme telles (champ `"synthetic": true`) ; aucun export de production n'est versionné. »*

CONDITION

Observed: `{"match_count": 1, "paths": ["tests/fixtures/clients_export_prod.json"]}`
Expected: `Zero versioned files containing production exports.`
Search returned 1 matches for production export markers in versioned files.

RISK

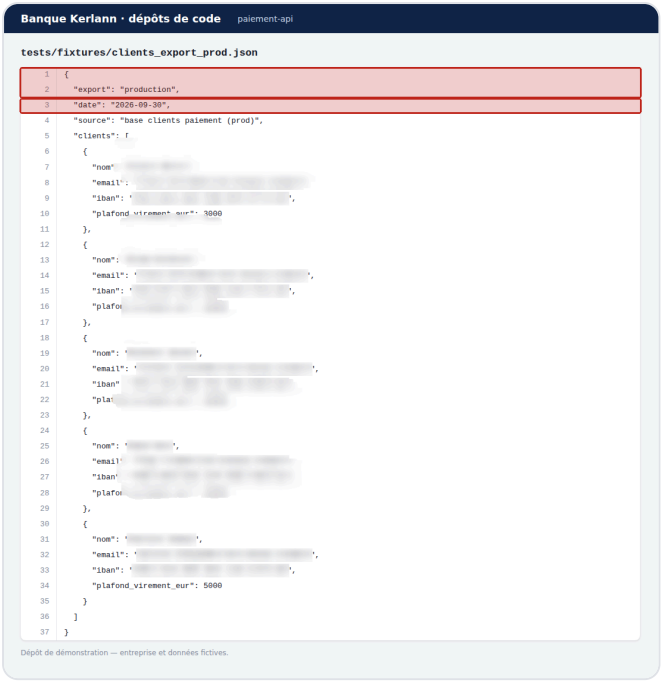
Versioned production exports breach confidentiality.

RECOMMENDATION

Remove any production exports from version control.
Due date: 2027-02-02 · Owner: IT department —

Payments development team

Test procedure: GET /api/repo/paiement-api/tree to list versioned files and GET /api/repo/paiement-api/search?q=production|prod_dump|real_data|dump\.csv to detect versioned production exports.



At testing — The screenshot corroborates the test. The versioned file declares export production from the prod payment client database. · 15/15 sensitive data items masked (5 spotted by the AI, the rest by the deterministic safety net)
`2026-11-04 06:00:35 · SHA-256 4d03f8cacfc68e09…`

F-06 PDS-2.7 Authentication successes and failures logged

Medium · Non-compliant · Open

CRITERIA

Verify application logs authentication successes and failures.
PDS-2.7 · RTS 12(2)(c)(i)
Threshold source: PDS-2.7

> *« Les réussites et les échecs d'authentification sont journalisés par l'application. »*

CONDITION

Observed: `{"path": "app/auth.py", "success_logs": [], "failure_logs": [], "search_matches": 0}`
Expected: `Application code logs both authentication successes and failures.`
app/auth.py is missing log lines for both success and failure.

RISK

Missing auth logs prevents detection of brute-force attacks.

RECOMMENDATION

Add logging for both authentication successes and failures.
Due date: 2027-05-03 · Owner: IT department — Payments development team

Test procedure: GET /api/repo/paiement-api/search?q=log.*auth|auth.*log|login.*log|logger\.(info|warning|error).*auth|audit.*login and GET /api/repo/paiement-api/file?path=app/auth.py to confirm both success and failure paths log.



At testing — The screenshot corroborates the test. The login function shows failure and success returns with no logging calls.
2026-11-04 06:00:50 · SHA-256 094fb6a83b17a595…

F-07 PDS-2.4 CI runs static security analysis

Medium | Non-compliant | Open

CRITERIA

Verify CI executes bandit, semgrep or CodeQL on every change.
PDS-2.4 · RTS 16(3)
Threshold source: PDS-2.4

> *« La chaîne d'intégration continue exécute une analyse statique de sécurité (bandit, semgrep ou CodeQL) à chaque modification. »*

CONDITION

Observed: `{"workflow_files": [".github/workflows/ci.yml"], "ci_contains_tool": false, "trigger_every_change": true, "workflow_search_matches": []}`
Expected: `Workflow contains bandit, semgrep or CodeQL executed on every change.`
ci.yml lacks bandit semgrep or CodeQL.

RISK

Missing static analysis leaves vulnerabilities undetected.

RECOMMENDATION

Add bandit, semgrep or CodeQL to CI on every change.
Due date: 2027-05-03 · Owner: IT department — Payments development team

Test procedure: GET /api/repo/paiement-api/tree to identify .github/workflows files, GET /api/repo/paiement-api/file?path=.github/workflows/ci.yml, and GET /api/repo/paiement-api/search?q=bandit|semgrep|CodeQL.



At testing — The screenshot corroborates the test. The displayed ci.yml only checks out code, sets up Python, installs dependencies and runs pytest with no bandit, semgrep or CodeQL step.
2026-11-04 05:59:08 · SHA-256 5b66c9f685aece43…

F-08 PDS-2.5 Dependencies pinned to exact version

Medium | Non-compliant | Open

CRITERIA

Verify all dependencies are pinned with ==.
PDS-2.5 · RTS 16(4) et 16(8)
Threshold source: PDS-2.5

> *« Les dépendances sont épinglées à une version exacte (`paquet==version`) et auditées en intégration continue (pip-audit ou équivalent). »*

CONDITION

Observed: `["flask", "requests>=2.0"]`
Expected: `Every dependency pinned to exact version with ==.`
2 of 3 dependencies in requirements.txt lack exact == pin.

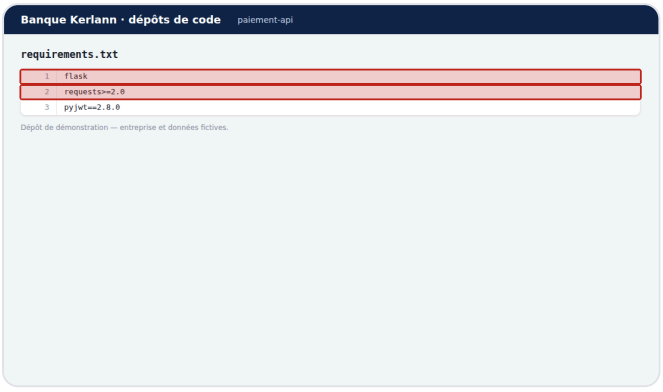
RISK

Unpinned dependencies allow untested and vulnerable versions.

RECOMMENDATION

Pin all dependencies to exact versions with ==.
Due date: 2027-05-03 · Owner: IT department — Payments development team

Test procedure: GET /api/repo/paiement-api/file?path=requirements.txt and verify each dependency line matches exact pin pattern with ==.



At testing — The screenshot corroborates the test. Screenshot shows flask with no version and requests with >= instead of ==, while only pyjwt uses ==.
2026-11-04 05:58:51 · SHA-256 94071ff0cc3ec301…

F-09 PDS-2.5 Dependencies audited in CI

Medium | Non-compliant | Open

CRITERIA

Verify dependencies are audited with pip-audit or equivalent in CI.
PDS-2.5 · RTS 16(4) et 16(8)
Threshold source: PDS-2.5

> *« Les dépendances sont épinglées à une version exacte (`paquet==version`) et auditées en intégration continue (pip-audit ou équivalent). »*

CONDITION

Observed: `{"ci_yml_text": "name: ci\non: [push]\njobs:\n test:\n runs-on: ubuntu-latest\n steps:\n - uses: actions/checkout@v4\n - uses: actions/setup-py…`
Expected: `CI workflow executes pip-audit or equivalent.`
ci yml contains no pip-audit or equivalent reference and no workflow audit match was found

RISK

RECOMMENDATION

Unaudited dependencies leave known vulnerabilities unaddressed.

Add pip-audit or equivalent audit to CI.
Due date: 2027-05-03 · Owner: IT department — Payments development team

Test procedure: GET /api/repo/paiement-api/tree to find workflows, GET /api/repo/paiement-api/file?path=.github/workflows/ci.yml, and GET /api/repo/paiement-api/search?q=pip-audit|pip_audit|safety|dependabot.

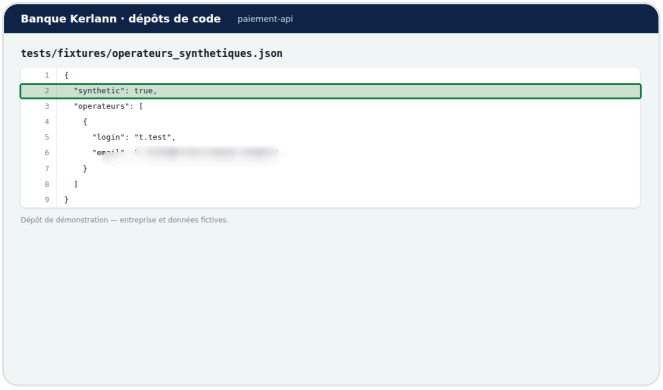


At testing — The screenshot corroborates the test. The displayed ci.yml shows only checkout, setup-python, install and pytest steps with no pip-audit or equivalent reference.
2026-11-04 05:59:11 · SHA-256 3d77cc1f911b2046…

PDS-2.6 Test data declared synthetic

High Compliant

Compliant control — Verify test data is synthetic and flagged. · RTS 16(5)(a)
Observed: `{"positive": ["tests/fixtures/operateurs_synthetiques.json"], "checked": ["tests/fixtures/clients_export_prod.json", "tests/fixtures/operateurs_synthetiques.jso…`



At testing — The screenshot corroborates the test. The file operateurs_synthetiques.json shows synthetic true on line 2. · 1/1 sensitive data items masked (0 spotted by the AI, the rest by the deterministic safety net)
2026-11-04 06:01:16 · SHA-256 3cd01f06e476e12d…

Appendices

A. Traceability matrix

REQUIREMENT	RULE	CONTROL	SCRIPT (SHA-256)	RESULT
RTS 7(2)	PDS-2.1	C1 · No hardcoded secrets in code or versioned config	686bcc935d92665d · written by AI for this engagement	Non-compliant
DORA 9(3)(a) ; RTS 6(2)(a)	PDS-2.2	C2 · TLS certificate verification never disabled	811567078a8a807a · written by AI for this engagement	Non-compliant
RTS 6(3) et 6(4)	PDS-2.3	C3 · Password hashing uses approved algorithm	12d819563bc5cea4 · written by AI for this engagement	Non-compliant
RTS 6(3) et 6(4)	PDS-2.3	C4 · MD5 and SHA-1 banned for security use	7fccfd98dd1a7591 · written by AI for this engagement	Non-compliant
RTS 16(3)	PDS-2.4	C5 · CI runs static security analysis	626623cafdc9804b · written by AI for this engagement	Non-compliant
RTS 16(4) et 16(8)	PDS-2.5	C6 · Dependencies pinned to exact version	29b89d4d59d8d530 · written by AI for this engagement	Non-compliant
RTS 16(4) et 16(8)	PDS-2.5	C7 · Dependencies audited in CI	05c75aa094e285bc · written by AI for this engagement	Non-compliant
RTS 16(5)(a)	PDS-2.6	C8 · Test data declared synthetic	e8caf64ba709e7ea · written by AI for this engagement	Compliant
RTS 16(5)(a)	PDS-2.6	C9 · No versioned production export	e5902ca6fd1eb85f · written by AI for this engagement	Non-compliant
RTS 12(2)(c)(i)	PDS-2.7	C10 · Authentication successes and failures logged	1969c15ce3b26a93 · written by AI for this engagement	Non-compliant

B. Evidence register

FILE			SHA-256
evidence/C1_before.png	C1 · At testing	2026-11-04 05:57:35	d881586620510d2452b450b9ecc625c5bcc29c3564e00b42b79030071c6829a9
evidence/C2_before.png	C2 · At testing	2026-11-04 05:58:04	03ffbdd593d56b5c2617e7935507798b8d74d6a1c2264c4c5f0bd6bf9de88b32
evidence/C3_before.png	C3 · At testing	2026-11-04 05:57:20	9b670c1eafd915cb6df201edf42dc67d9cd479c769ad7b5f49bc574e294bd891
evidence/C4_before.png	C4 · At testing	2026-11-04 05:57:08	9b670c1eafd915cb6df201edf42dc67d9cd479c769ad7b5f49bc574e294bd891
evidence/C5_before.png	C5 · At testing	2026-11-04 05:59:08	5b66c9f685aece43e72a3c51af1b4397dae1881238a1d29f43d83d6113510df9
evidence/C6_before.png	C6 · At testing	2026-11-04 05:58:51	94071ff0cc3ec3013b5c4620d989ef9e69def04847069f8c7a03fba625a6574f

evidence/C7_before.png	C7 · At testing	2026-11-04 05:59:11	3d77cc1f911b2046188cc5d2b5d0b6cfcc7f2632f444e8dc4bc62adf764595ce
evidence/C8_before.png	C8 · At testing	2026-11-04 06:01:16	3cd01f06e476e12d5f7f97ba50f3267f4aac7aeba4eefe81306a59c7682be965
evidence/C9_before.png	C9 · At testing	2026-11-04 06:00:35	4d03f8cacfc68e09bc39a612ed021f435421b327f4dc4f54c817fae3d3ab9da4
evidence/C10_before.png	C10 · At testing	2026-11-04 06:00:50	094fb6a83b17a595cf251c0029caf75f39896e0b9920389c46e966a51130a034

C. AI usage, costs and human oversight

MODEL	CALLS	INPUT TOKENS	OUTPUT TOKENS	IMAGES	COST (USD)
muse-spark-1.3	23	29,526	164,984	0	0.7381
sam-3.1	11	0	0	11	price not published
Total					**0.7381**

Sensitive data (personal data and secrets) in evidence: 7/19 spotted by Muse Spark + SAM, 19/19 masked in the end thanks to the deterministic safety net (page text).

* sam-3.1: price not published (pricing.toml)

Safeguards

- Scripts: allow-listed imports, no write requests (static analysis before execution).
- Read-only test account: any write would be refused by the system (defence in depth).
- Fixes: allow-listed route and parameters, human approval, separate change account.
- Segregation of duties: the approver cannot be the auditor.

D. Integrity

Audit-trail fingerprint when the report was issued. Verify with `python -m attest verify <folder>`.

73ac90afb8d16bba14f181b79f0be62f2183b60d0524809140c47d927d303cfe

F. Framework coverage

20 requirements read: 11 tested automatically (10 controls; 4 regulation clauses covered through the policy), 9 left to document review, 0 to interviews, 0 rejected for lack of an exact quote. Attest only covers the first group.

REF.	TEXT (VERIFIED QUOTE)	TESTABILITY	CONTROL	
RTS 16(1)	« financial entities shall develop, document and implement a policy governing the acquisition, development, and maintenance of ICT systems. »	**document review**	0	Policy existence and documentation cannot be verified through read-only code access.

RTS 16(1)(a)	« identify security practices and methodologies relating to the acquisition, development, and maintenance of ICT systems; »	**document review**	0	Policy content requires document review and is not visible in source code.
RTS 16(1)(c)	« specify measures to mitigate the risk of unintentional alteration or intentional manipulation of the ICT systems during development, maintenance, and deployment. »	**document review**	0	Mitigation measures in process require document review, not code search.
RTS 16(2)	« financial entities shall develop, document, and implement an ICT systems' acquisition, development, and maintenance procedure for the testing and approval of all ICT systems prior to their use and after maintenance. »	**document review**	0	Procedure existence and approval workflow require document review.
RTS 16(3)	« the procedure shall contain source code reviews covering both static and dynamic testing, including security testing for internet-exposed systems and applications. »	**tested automatically**	→ PDS-2.4	Static testing obligation is verifiable in CI via the repository interface and is covered by policy control.
RTS 16(3)(a)	« identify and analyse vulnerabilities and anomalies in the source code; »	**document review**	0	Identification reports and analysis require document review beyond code search.
RTS 16(3)(b)	« adopt an action plan to address those vulnerabilities and anomalies; »	**document review**	0	Action plan existence requires document review, not repository reads.
RTS 16(3)(c)	« monitor the implementation of that action plan. »	**document review**	0	Monitoring evidence requires tracking documents, not code alone.
RTS 16(4)	« the procedure shall contain security testing of software packages no later than at the integration phase. »	**tested automatically**	→ PDS-2.5	Integration-phase package auditing is verifiable in CI and dependencies via the repository interface.
RTS 16(5)(a)	« non-production environments only store anonymised, pseudonymised, or randomised production data; »	**tested automatically**	→ PDS-2.6	Test data synthetic character is verifiable in repository fixtures and is covered by policy control.
RTS 16(5)(b)	« financial entities are to protect the integrity and confidentiality of data in non-production environments. »	**document review**	0	Environment access and protection controls are not visible in source code.

RTS 16(7)	« the procedure shall include controls to protect the integrity of source code of ICT systems that are developed in-house or by an ICT third-party service provider. »	**document review**	0	Integrity controls like branch protection and signing need document review, interface has no history.
RTS 16(8)	« proprietary software and, where feasible, the source code provided by ICT third-party service providers, as well as source code coming from open-source projects, are to be analysed and tested in accordance with paragraph »	**tested automatically**	→ PDS-2.5	Dependency analysis and testing is verifiable via requirements and CI and is covered by policy control.
PDS-2.1	« Aucun secret (mot de passe, clé, jeton) n'est écrit en clair dans le code source ni dans la configuration versionnée : les secrets viennent d'un coffre ou de variables d'environnement. »	**tested automatically**	1	Hardcoded secrets are detectable via repository search and file reads.
PDS-2.2	« Tout appel réseau sortant vérifie le certificat TLS du serveur : la vérification n'est jamais désactivée (`verify=False` interdit). »	**tested automatically**	1	Disabled TLS verification is detectable via repository search.
PDS-2.3	« Les mots de passe sont hachés avec argon2, bcrypt, scrypt ou PBKDF2. MD5 et SHA-1 sont interdits pour tout usage de sécurité. »	**tested automatically**	2	Hashing libraries and banned hashes are detectable via repository search.
PDS-2.4	« La chaîne d'intégration continue exécute une analyse statique de sécurité (bandit, semgrep ou CodeQL) à chaque modification. »	**tested automatically**	1	CI configuration is readable via repository tree and workflow files.
PDS-2.5	« Les dépendances sont épinglées à une version exacte (`paquet==version`) et auditées en intégration continue (pip-audit ou équivalent). »	**tested automatically**	2	Requirements file and CI workflow are readable via repository interface.
PDS-2.6	« Les données de test sont synthétiques et déclarées comme telles (champ `"synthetic": true`) ; aucun export de production n'est versionné. »	**tested automatically**	2	Test fixtures and file list are readable via search and tree.
PDS-2.7	« Les réussites et les échecs d'authentification sont journalisés par l'application. »	**tested automatically**	1	Logging calls are detectable via repository search in application code.